情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#13

ネットワークセキュリティの方式と製品

境界で止める、内側でも分ける、クラウドの使い方も見る

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、NIST SP 800-41・94・113・207、Nmap、Cisco など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類6「情報システムの適正利用の管理」

1 境界での通信の制御
FW 3方式、NIDS・HIDS、SSL-VPN 3方式

2 内部への接続と公開サービス
検疫・NAC・MAC フィルタ・DHCP スヌーピング・VLAN・マイクロセグメンテーション、リバースプロキシ・DDoS 対策、ポートスキャン

3 製品とクラウド
UTM・WAF・VDI、CASB・CSPM・CWPP・SASE・ZTNA

過去の午前 II での出方（13回出題）

テーマ	出た回
ステートフル（ダイナミック）の特徴	H31春・R1秋・R3春・R3秋
CASB の効果	R3春・R4秋・R6春
VDI でマルウェアと流出を防ぐ条件	H31春・R3春
DB を内部に移すときの FW ルール	R2・R5秋
CSPM の機能	R7秋
VLAN の効果	H31春

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類6／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

境界での通信の制御

何を見て、どこまで止めるか。

ファイアウォールの3方式

方式	見る層	判断のしかた	長所・短所
パケットフィルタリング型	L3・L4	パケット1個ずつ、アドレス・ポート・プロトコルをルールと照合	速い／戻り用に広く開けがち
ステートフルインスペクション型	L3・L4+状態	通過したパケットからセッションを認識し、**状態に照らして**判断。戻りのパケットだけ自動で通す	現在の主流
アプリケーションゲートウェイ型	L7	プロトコルごとのプロキシが接続を受け付け、中身を検査して**改めて接続**	中身まで見る／遅い・対応プロトコル限定

R3秋 問6 の誤りの選択肢：IP アドレスの変換で隠蔽＝NAT、暗号化されたデータ部を復号＝TLS 復号、データ部を見てアプリ層の不正を防止＝アプリケーションゲートウェイ／WAF。

R3春 問6：「リバースプロキシとして動作」＝WAF、「プロトコルごとにプロキシ」＝アプリケーションゲートウェイ。

出典：NIST SP 800-41 Rev.1 Guidelines on Firewalls and Firewall Policy 2.1／IPA 午前 II 令和3年度春期 問6・秋期 問6

NIDS と HIDS、SSL-VPN の3方式

	NIDS	HIDS
置き場所	ネットワーク（ミラーポートなど）	監視するホストの中
見るもの	流れる通信	ログ・ファイル改ざん・プロセス
暗号化通信	**中身は見えない**	復号後を見られる
手間	1台でセグメント全体	ホストごとに導入

SSL-VPN	しくみ	使えるもの
リバースプロキシ方式	ブラウザ → 装置が中継	Web だけ
ポートフォワーディング方式	端末のモジュールが特定ポートを転送	決まった TCP
L2 フォワーディング方式	仮想 NIC でフレームを運ぶ	UDP 含むほぼ全部

> L2 フォワーディングは LAN にいるのと同じ → 感染端末も社内全体に届く。接続時の端末検査が要る。

出典：NIST SP 800-94 Guide to IDPS／NIST SP 800-113 Guide to SSL VPNs／IPA「支援士試験 シラバス（案）」用語例「VPN（リバースプロキシ方式, ポートフォワーディング方式, L2 フォワーディング方式）」

DMZ と FW ルール（R2・R5秋 の考え方）

変更後の構成（DB サーバを内部へ）



通信	ルール
インターネット → WebAP（HTTPS）	許可
WebAP → DB（ODBC の特定ポート）	追加
運用管理 PC → 各サーバ（SSH）	許可
インターネット → DB	不要（拒否）
戻りのパケット	状態で自動許可

> ステートフル型なら、**戻りの通信のルールは書かない**。必要な「行き」だけを許可。

出典：IPA 午前 II 令和2年度 問14・令和5年度秋期 問17 の条件をもとに Claude が整理（図は略図）

第2章

内部への接続の制御と公開サービスの保護

入る端末を選び、中も分け、表の玄関を強くする。

内部ネットワークへの接続を制御する

検疫ネットワークの流れ

隔離 → **検査**（パッチ・定義ファイル） → **治療**（更新させる） → **接続**

NAC：認証＋端末の健全性の検証で接続先 VLAN を決める。仕様の一つが TCG の **TNC**。

MAC アドレスフィルタリングは偽装に弱い。単独では不十分。

DHCP スヌーピング

信頼ポート：正規の DHCP サーバ
OFFER・ACK を通す

非信頼ポート：偽の DHCP サーバ
応答を捨てる

対応表（IP・MAC・ポート）
ダイナミック ARP インスペクションにも使う

VLAN（H31春 問12）：ブロードキャストの届く範囲を制限 → アドレス情報の不要な流出を減らす。

出典：IPA「支援士試験 シラバス（案）」用語例〔内部ネットワークへの接続の制御〕／TCG「TNC Architecture」／Cisco「DHCP スヌーピングの設定」／IPA 午前 II 平成31年度春期 問12

公開サービスを守る：DDoS と Bot

対策	しくみ	効く攻撃
リバースプロキシ	表で受けて中継。TLS 終端・負荷分散・WAF をまとめる	サーバを直接さらさない
CDN	世界中のキャッシュ拠点で配信	大量の要求を拠点で吸収
Anycast	同じ IP を多拠点から広告、近い拠点へ	攻撃を拠点に分散
スクラビングセンター	BGP・DNS で引き込み、攻撃を除いて返す	回線容量を超える攻撃
レート制限	送信元・利用者ごとの要求数に上限	L7 の DDoS・パスワードリスト攻撃
CAPTCHA	人か機械かを判定する問題	Bot の大量登録・購入

> 回線があふれる攻撃は、自社の FW やサーバ増設では防げない。**上流で**取り除く。

出典：IPA「支援士試験 シラバス（案）」用語例〔公開サービスの保護〕

マイクロセグメンテーションとポートスキャン

横移動を止める

侵入された Web → DB（必要なポートだけ許可）

侵入された Web × 人事・経理のサーバ

ワークロード単位で分ける。ゼロトラスト（#18）の実装技術。

TCP SYN スキャンの判定

応答	状態
SYN/ACK	open
RST	closed
応答なし・ICMP 到達不能	filtered

自組織の検査は**許可と時間帯**を決めて。他人の資産を調べない。

出典：NIST SP 800-207 Zero Trust Architecture 3.1.2／Nmap Reference Guide「Port Scanning Techniques」

第3章

セキュリティ製品とクラウドのサービス

「設定」「中身」「使い方」のどれを見るか。

VDI でインターネットを隔てる（H31春・R3春 問16）

内部の PC ⇄ 画面転送プロトコルだけ ⇄ DMZ の VDI（仮想マシンのブラウザ） ⇄ インターネットの Web

選択肢	判定
画面転送＋ファイル転送	持込み・持出しができる
画面転送だけ	正解
VDI が HTTP を中継	Web の内容が PC に届く
VDI が画面転送を中継	PC との間の制限にならない

UTM：FW・IPS・AV・URL フィルタ・VPN を1台に。**性能低下と単一障害点**に注意。

WAF：HTTP の中身で判断。脆弱性を直すまでの**仮想パッチ**。

出典：IPA 午前 II 平成31年度春期 問16・令和3年度春期 問16／IPA「支援士試験 シラバス（案）」用語例「統合脅威管理（UTM），WAF」

クラウドのセキュリティサービスを見分ける

名前	見るもの	何をするか	過去問
CASB	使い方	従業員のクラウド利用を可視化・制御。**シャドー IT**の特定	R3春・R4秋・R6春
CSPM	設定	設定を継続的に監視し、**不適切な設定**を検知	R7秋 問15
CWPP	中身	VM・コンテナ・サーバレスの脆弱性・マルウェア・実行時の動作	—
SASE	経路	SD-WAN＋SWG・CASB・ZTNA・FWaaS をクラウドから一体で	—
ZTNA	接続	毎回検証し、許可した**アプリ単位**で接続（VPN の代わり）	—

CASB の誤りの選択肢は「プロバイダが DDoS 対策」「プロバイダが入退室管理」「利用者側が脆弱性診断」。CASB は**利用する組織**が**利用状況**を見るもの。

出典：IPA 午前 II 令和6年度春期 問11・令和7年度秋期 問15／IPA「支援士試験 シラバス（案）」用語例〔クラウド・SaaS〕

まとめ：本番での問われ方

ステートフル：過去に通過したパケットからセッションを認識 → 戻りのパケットを通す。NAT・復号・アプリ層の検査は別物。

NIDS／HIDS：暗号化された中身はホスト側で。**SSL-VPN：**Web だけ／特定 TCP／ほぼ全部。

接続制御：検疫＝隔離→検査→治療→接続。偽 DHCP には DHCP スヌーピング。VLAN でブロードキャストを閉じ込める。

DDoS：回線を超えるならスクラビングセンター。分散は Anycast・CDN。L7 はレート制限。

VDI：PC との間は画面転送だけ。

クラウド：CASB＝使い方（シャドー IT）、CSPM＝設定、CWPP＝ワークロード、SASE＝まとめてクラウドから。

出典：IPA 午前 II（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」